

Task 4 — Detailed Penetration Test Findings & Report

1. Executive Summary

A controlled penetration test was performed against the Metasploitable2 lab host (192.168.0.102) using Kali Linux. The engagement followed a standard pentest flow: reconnaissance (Nmap, whois, traceroute), vulnerability scanning (Nessus), and targeted exploitation (Metasploit). Multiple high- and critical-severity vulnerabilities were identified. A successful remote code execution exploit against Samba (CVE-2007-2447) yielded a root shell, confirming full system compromise. Detailed findings and remediation guidance follow.

2. Scope & Objectives

- **Scope:** Single host — Metasploitable2 (192.168.0.102) in an isolated VirtualBox lab.
- **Objectives:**
 - Discover open ports and running services.
 - Identify known vulnerabilities and misconfigurations.
 - Exploit critical vulnerabilities to demonstrate impact (ethical, lab-only).
 - Produce remediation guidance and validation steps.

(Sources: Task 1 reconnaissance and Task 2 Nessus scan summary).

3. Methodology

1. Reconnaissance

- whois, traceroute, and nmap -A -T4 to enumerate network and services. (See Task 1.)

2. Vulnerability Scanning

- Nessus Essentials basic network scan used to identify CVEs and severity levels. (See Task 2.)

3. Exploitation

- Metasploit used to exploit high/critical findings (Samba usermap_script) and verify root-level access. (See Task 3.)
-

4. Summary of Key Findings (Consolidated)

The most important, high-impact findings discovered and validated during the engagement:

- **Samba — username map script RCE (CVE-2007-2447)**
 - Ports: 139/445 (SMB).
 - Severity: Critical (RCE).
 - Evidence: Successful Metasploit exploit / reverse shell; whoami returned root.
- **vsftpd 2.3.4 Backdoor (CVE-2011-2523)**
 - Port: 21 (FTP).
 - Severity: Critical — backdoor allows remote command execution (anonymous FTP present).
- **UnrealIRCd backdoor (CVE-2010-2075)**
 - Port: 6667 (IRC).
 - Severity: Critical — remote shell possible.
- **ProFTPD mod_copy (CVE-2015-3306)**
 - Port: 2121 (FTP alternative).
 - Severity: Critical — arbitrary file copy leading to code execution.
- **Apache Tomcat with Default Credentials (CVE-2009-3548)**
 - Port: 8180.
 - Severity: Critical/High — default admin credentials can allow WAR deployment and remote code execution.
- **Exposed Databases**
 - MySQL (3306) and PostgreSQL (5432) accessible; multiple version-specific issues found.
- **Other issues**
 - SSLv2 enabled on SMTP (deprecated and insecure), many legacy/unused services (telnet, rlogin, rexec), banner disclosure, and weak/old SSH version.

(Full list and counts of Critical/High/Medium/Low were documented in Task 2.)

5. Proof of Compromise (Evidence)

- Metasploit session opened via exploit/multi/samba/usermap_script with reverse handler.

- Shell output from the compromised host demonstrated root privileges (sample): `whoami -> root;` interactive bash shell on `/bin/bash`.

(Full command sequence and proof are recorded in the Task 3 report).

6. Risk Assessment (Prioritized)

High-level risk assessment with recommended priority:

Vulnerability / Issue	Likelihood	Impact	Priority
Samba RCE (CVE-2007-2447)	High	Complete system compromise	Immediate
vsftpd backdoor	High	Remote code execution	Immediate
UnrealIRCd backdoor	High	Remote shell	Immediate
ProFTPD mod_copy	High	File/Code execution	Immediate
Default Tomcat creds	High	Application takeover	High
Exposed DBs (MySQL/Postgres)	Medium	Data exfiltration	High
SSLv2 on SMTP	Medium	MITM risk	Medium
Banner disclosure / deprecated services	Medium	Recon facilitation	Medium

(Assessment based on exploitability, impact, and lab verification).

7. Remediation & Hardening Recommendations (Actionable)

Prioritized, practical steps you can implement:

Immediate (within 24–72 hours)

1. **Isolate the affected host** from production networks (if this were a real host).
2. **Patch/upgrade Samba** to a secure, supported release; confirm fix for CVE-2007-2447. If immediate patching isn't possible, block SMB ports (139/445) at network perimeter/firewall.
3. **Disable anonymous FTP** and update/remove vsftpd 2.3.4; upgrade to a maintained FTP server or disable if unused.
4. **Remove or disable backdoored/legacy services** (UnrealIRCd, ProFTPD) or replace with patched versions.

5. **Change default credentials** and audit admin interfaces (Tomcat manager) — disable or restrict by IP.

Short-term (1–4 weeks)

1. **Regenerate SSH host keys** and move to modern OpenSSH with strong configuration (disable insecure ciphers/MACs).
2. **Disable SSLv2** protocol support on all services; enforce TLS 1.2+.
3. **Harden database access**: restrict listening interfaces to localhost or internal subnets, enforce strong passwords, and enable encryption/auth plugins.
4. **Remove unnecessary services** (telnet, rlogin, rexecd) completely.

Medium-term (1–3 months)

1. **Implement network segmentation** to limit lateral movement.
2. **Deploy IDS/IPS and central logging** (SIEM) to detect anomalous activities.
3. **Implement patch management** and regular vulnerability scanning cadence (weekly/monthly).
4. **Perform code/app review** for web applications and enforce secure coding practices.

Long-term

- Regular security training, change management, and periodic full-scope penetration tests.

8. Validation Plan (How to confirm fixes)

1. **Re-run Nessus** scan after each patch cycle and compare results to baseline (Task 2). Verify that the vulnerabilities are marked as “fixed.”
2. **Run targeted verification tests** (e.g., re-run the Metasploit module against Samba in a safe manner) only after change approval.
3. **Perform regression tests** to ensure functionality remains intact.
4. **Document changes** in a remediation log (date, change, responsible person, verification evidence).

9. Conclusion

The Metasploitable2 host intentionally contained multiple critical vulnerabilities which were discovered and exploited during the assessment. In a production setting, these vulnerabilities would enable complete system takeover and data loss. Immediate remediation of the critical findings is strongly recommended, followed by the broader hardening steps outlined above.